

Acme Corp Information Security Policy

Version 2.4 | Effective: January 1, 2026 | Classification: Internal

Owner: Information Security Team | Review Cycle: Annual

This document defines the information security policies and standards for all employees, contractors, and third parties who access Acme Corp systems or data. Compliance with this policy is mandatory. Violations may result in disciplinary action up to and including termination.

1. Password Policy

1.1 Password Requirements

All user account passwords must meet the following minimum requirements:

Requirement	Standard
Minimum length	14 characters
Character classes required	Uppercase, lowercase, digit, and symbol
Maximum age	90 days
Minimum age	1 day (prevents immediate reuse)
History	Last 12 passwords cannot be reused
Lockout threshold	5 failed attempts
Lockout duration	30 minutes or until administrator reset

1.2 Multi-Factor Authentication (MFA)

MFA is mandatory for all accounts with access to: production systems, administrative consoles, cloud infrastructure, VPN, and any system storing or processing Personally Identifiable Information (PII) or payment card data. Acceptable MFA methods are: hardware security keys (FIDO2/WebAuthn), authenticator apps (TOTP), and SMS as a last resort. SMS-based MFA is deprecated and will be removed by Q3 2026.

1.3 Service Account Credentials

Service account passwords must be at least 32 characters in length, randomly generated, and stored exclusively in the approved secrets manager (HashiCorp Vault). Service accounts must not be used for interactive logins. All service account credentials must be rotated every 180 days.

2. Data Classification

Acme Corp classifies all data into four tiers. Each tier carries specific handling, storage, and transmission requirements.

Tier	Label	Examples	Encryption Required
1 (Highest)	Restricted	PII, payment data, health records	At rest and in transit
2	Confidential	Business plans, source code	At rest and in transit
3	Internal	Policies, org charts	In transit
4 (Lowest)	Public	Marketing material	Optional

3. Acceptable Use Policy

3.1 Permitted Activities

Company systems and networks may be used for: conducting Acme Corp business, approved software development and testing, accessing training and professional development resources, and incidental personal use that does not interfere with business operations.

3.2 Prohibited Activities

The following activities are strictly prohibited on Acme Corp systems: accessing, storing, or distributing illegal content; installing unauthorised software or circumventing security controls; sharing credentials or granting unauthorised access to others; using company resources for personal financial gain or outside business activities; connecting unapproved personal devices to internal network segments; attempting to access systems or data beyond the scope of your role.

4. Incident Response

All suspected security incidents must be reported to security@acmecorp.example within one hour of discovery. An incident is defined as any event that threatens the confidentiality, integrity, or availability of Acme Corp systems or data.

Phase	Owner	SLA
Detection	Any employee	Report within 1 hour
Triage	Security team	Acknowledge within 2 hours
Containment	Security + IT Ops	Within 4 hours of triage
Eradication	Security team	Within 24 hours
Recovery	IT Ops	Within 48 hours
Post-mortem	Security + affected teams	Within 5 business days

5. Remote Work and VPN

All remote access to internal Acme Corp systems must be made through the company-approved VPN (Tailscale). Split-tunnel VPN is not permitted for Restricted or Confidential data. Employees must not use public Wi-Fi networks without VPN active. Home routers must use WPA3 encryption where supported, or WPA2 as a minimum.

5.1 Approved Devices

Only Acme Corp-managed devices with current endpoint protection software and full-disk encryption enabled may connect to internal systems. Personal device access is limited to email and calendar via the approved web portal only.

6. AI and Machine Learning Tools

Employees may use approved AI coding assistants and productivity tools listed in the approved software catalogue. Inputting Restricted or Confidential data into any external AI service (including public LLM APIs) is strictly prohibited without written approval from the CISO. All AI-generated code must be reviewed by a human engineer before merging to production. Security testing of internal AI systems must follow the procedures in Annex A.